

# Security Linter Report

|                     |                         |
|---------------------|-------------------------|
| Filename            | case4_sql_i_printf.py   |
| Timestamp           | 2026-05-22 00:31:25 UTC |
| Lines of Code (LOC) | 3                       |
| Verdict             | VULNERABLE              |

| ID         | Severity | Sink       | Source Variable | Source Type | Line |
|------------|----------|------------|-----------------|-------------|------|
| CVE-SL-002 | CRITICAL | db.execute | sql             | HTTP_ARGS   | 3    |

|          |   |
|----------|---|
| CRITICAL | 1 |
| WARNING  | 0 |
| INFO     | 0 |
| TOTAL    | 1 |

**CVE-SL-002 — db.execute****CRITICAL**

|                              |                                     |
|------------------------------|-------------------------------------|
| <b>CWE</b>                   | CWE-89                              |
| <b>Sink</b>                  | db.execute                          |
| <b>Sink Line</b>             | 3                                   |
| <b>Sink Column</b>           | 0                                   |
| <b>Sink Expression</b>       | db.execute(sql)                     |
| <b>Argument</b>              | sql                                 |
| <b>Source Variable</b>       | sql                                 |
| <b>Source Type</b>           | HTTP_ARGS                           |
| <b>Propagation Mechanism</b> | direct assignment from HTTP request |

***Taint Path Trace:***

| Step | Role   | Line | Expression                                                      |
|------|--------|------|-----------------------------------------------------------------|
| 1    | SOURCE | 2    | sql = "SELECT id FROM accounts WHERE login = '%s'" % usernam... |
| 2    | SINK   | 3    | db.execute(sql)                                                 |

***Remediation:***

Use a parameterized query. Never interpolate HTTP parameters directly into SQL:

```
name = request.args.get("name")
query = "SELECT * FROM users WHERE name = %s"
cursor.execute(query, (name,))
```

No safe sink paths confirmed.

No sanitization functions detected.

|                                          |                |
|------------------------------------------|----------------|
| CFG — Total Nodes                        | 5              |
| CFG — Condition/Loop Nodes               | 0              |
| CFG — Assignment Nodes                   | 2              |
| CFG — Call Nodes                         | 1              |
| CFG — Merge Nodes                        | 0              |
| ████████████████████████████████████████ | ██████████████ |
| DFG — Total Nodes                        | 12             |
| DFG — Total Edges                        | 11             |
| DFG — Source Nodes                       | 3              |
| DFG — Sink Nodes                         | 1              |
| DFG — Operator Nodes                     | 1              |
| DFG — Constant Nodes                     | 2              |
| DFG — Variable Nodes                     | 5              |
| Taint Propagation Hops                   | 5              |
| ████████████████████████████████████████ | ██████████████ |
| Analysis Time (ms)                       | 28.2           |

|                        |                                 |
|------------------------|---------------------------------|
| <b>Vulnerabilities</b> | 1 CRITICAL   0 WARNING   0 INFO |
| <b>Safe Sinks</b>      | 0                               |
| <b>Analysis Time</b>   | 28.2 ms                         |
| <b>Engine Version</b>  | 1.0.0                           |
| <b>Final Verdict</b>   | <b>VULNERABLE</b>               |